

TD1 : Analyse de CVE

Exercice 1

A partir de la description suivante, répondre aux questions :

PHPMailer 6.1.8 through 6.4.0 allows object injection through Phar Deserialization via addAttachment with a UNC pathname. NOTE: this is similar to CVE-2018-19296, but arose because 6.1.8 fixed a functionality problem in which UNC pathnames were always considered unreadable by PHPMailer, even in safe contexts. As an unintended side effect, this fix eliminated the code that blocked addAttachment exploitation.

Q1 : Quel est le nom de l'application vulnérable ?

PHPMailer

Q2 : A quoi sert (ou comment est utilisée) cette application ? (Utiliser un moteur de recherche)

PHPMailer est une bibliothèque logicielle d'envoi d'e-mails en PHP

Q3 : Quelles sont les versions vulnérables ?

de la 6.1.8 à la 6.4.0

Q4 : Quelle est la cause de cette vulnérabilité ? (Comprendre « Phar Deserialization » et « UNC pathname »)

Q5 : Quelle est la catégorie de vulnérabilité parmi celles-ci :

- Authentification
- Autorisation
- Cryptographie
- Corruption de mémoire
- Injection de code
- Gestion de session

Q6 : Comment pourrait-on exploiter cette vulnérabilité ? (le principe général)

Exercice 2

A partir de la description suivante, répondre aux questions :

An issue was discovered in GFI Kerio Control 9.2.5 through 9.4.5. The dest GET parameter passed to the /nonauth/addCertException.cs and /nonauth/guestConfirm.cs and /nonauth/expiration.cs pages is not properly sanitized before being used to generate a Location HTTP header in a 302 HTTP response. This can be exploited to perform Open Redirect or HTTP Response Splitting attacks, which in turn lead to Reflected Cross-Site Scripting (XSS). Remote command execution can be achieved by leveraging the upgrade feature in the admin interface.

Q1 : Quel est le nom de l'application vulnérable ?

GFI Kerio Control

Q2 : Retrouver une page web qui exploite comment exploiter cette vulnérabilité. Comment faut-il encoder le paramètre « dest » ?

<https://karmainsecurity.com/hacking-kerio-control-via-cve-2024-52875>

Q3 : Quelle extension de fichier doit être utilisée pour exécuter du code sur le serveur ?

Q4 : Quels sont les droits obtenus de l'utilisateur en cas d'exécution de code réussie ?

Exercice 3

Retrouver la vulnérabilité suivante sur le site NVD du NIST : CVE-2021-44228

Q1 : Quel est le nom de l'application vulnérable ?

Log4j

Q2 : Quelles sont les versions vulnérables ?

2.0-beta9 jusqu'a 2.15.0 sauf 2.12.2, 2.12.3

Q3 : Quel est son score CVSS v3 ?

10

Q4 : Pourquoi cette valeur est-elle si élevée ?

le CIA est haut (confidentiality, integrity , availability)

Q5 : Quelle est sa date de publication ?

10 décembre 2021

Q6 : Quelle est la date et l'heure de la dernière modification de cette CVE ?

03 AVRIL 2025

Exercice 4

Retrouver la vulnérabilité suivante sur le site NVD du NIST : CVE-2021-4259

Q1 : Quel est le nom de l'application vulnérable ?

Q2 : Quelles sont les versions vulnérables ?

Q3 : Quel est le score CVSS v3 donné par NVD ?

Q4 : Quel est le nom du fichier vulnérable ?

Q5 : Quel est le numéro de ligne dans ce fichier qui est vulnérable ?

Q6 : Quelle est la correction faite dans le patch ? (le *commit*)

Q7 : En regardant le code du *commit*, quelle serait la technique générale pour exploiter cette vulnérabilité ? (sans rentrer dans les détails techniques)

Q8 : La plupart du temps, cette erreur commune a peu de conséquences. Pourquoi est-elle plus élevée dans ce cas-là ? Si vous avez trouvé, donner le nom de la catégorie de vulnérabilité.

Exercice 5

Effectuer une recherche sur le site NVD du NIST pour afficher les CVE de : Tomcat version 9.0.31

Q1 : Combien de CVE ont été trouvées ?

Q2 : Quelle est la CVE qui a le CVSS v3.1 le plus élevé ?

Q3 : Que permet de faire cette CVE pour l'attaquant ?

Q4 : Quelle est la condition (pour l'attaquant) pour exploiter cette CVE ?

Q5 : Afficher le code d'exploitation. Quelle est la difficulté d'exploitation de cette CVE ?

Exercice 6

Aller sur : <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>

Q1 : Déterminer le CVSS v3.1 en fonction des métriques suivantes :

AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Base score :

Q2 : Déterminer le CVSS v3.1 en fonction des métriques suivantes :

AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

Base score :

Exercice 7

Aller sur <https://www.exploit-db.com/>

Q1 : Effectuer une recherche avancée pour trouver le type = webapps et tag = LFI/RFI et afficher le résultat correspondant au 22 janvier 2019. Quel est le nom de l'application vulnérable ?

Q2 : Sur quel système ce code a-t-il été testé ?

Q3 : Quel est l'encodage utilisé pour le paramètre « file » ?